Northwind Labs Information Security Policy

Policy code SEC-POL-01. Version 3.0. Effective 1 January 2026. Owner: Head of Security. Classification: Internal.

SEC-01 Scope and responsibilities

This policy applies to everyone who has access to Northwind Labs systems or data, including employees, interns, contractors and vendors. It covers company laptops and phones, cloud accounts, source code, production systems and every copy of company or customer data, wherever it is stored.

The security team owns this policy and reviews it every year. Managers are responsible for making sure their teams follow it. Exceptions are requested with form SEC-F03 and can be approved by the Head of Security for up to 90 days at a time. An exception that is still needed after 90 days must be requested again.

SEC-02 Acceptable use

Company devices and accounts are provided for work. Limited personal use, such as reading the news or making a personal payment, is acceptable as long as it does not affect work or break this policy.

The following are never allowed on company devices or accounts: installing pirated or unlicensed software, mining cryptocurrency, disabling or bypassing security tools, sharing an account or password with another person, and storing personal media libraries.

SEC-03 Identity, passwords and multi-factor authentication

All company accounts sign in through NorthID, the company single sign-on service. Passwords must be at least 14 characters long and must not be reused for any other service. Passwords are not rotated on a fixed schedule. A password must be changed immediately if there is any reason to think it has been exposed.

Security keys (FIDO2 hardware keys) are required for engineers with production access and for all administrators. Other employees may use the NorthID authenticator app as their second factor. SMS codes are not an accepted second factor for any company account.

After 5 failed sign-in attempts in a row, the account is locked for 15 minutes. Repeated lockouts are reported to the security team automatically.

SEC-04 Device security

Company laptops are enrolled in FleetGuard, the device management service, before first use. FleetGuard enforces full-disk encryption, the built-in firewall and a screen lock after 5 minutes of inactivity. These settings cannot be changed by the user.

Operating system updates must be installed within 14 days of release, and updates marked critical within 72 hours. FleetGuard shows a warning when an update is overdue and restricts access to company systems once the deadline has passed.

USB mass-storage devices are blocked on all company laptops. Files should be shared through the company drive instead. Lost or stolen devices must be reported in the #security-help channel as soon as possible so that the device can be locked and wiped remotely.

SEC-05 Personal devices

Personal phones may be used for company email, chat and calendar only through the FleetGuard work profile, which keeps company data separate from personal apps. Personal laptops and tablets must never be used to access source code, production systems or customer data, even through a web browser.

SEC-06 Data classification

Northwind Labs data is classified into four levels: Public, Internal, Confidential and Restricted. The owner of a document or dataset is responsible for labelling it, and anything without a label is treated as Internal.

Public data is approved for anyone to see, such as published marketing pages and open-source code. Internal data is general company information, such as this policy or team plans. Confidential data includes customer business data, contracts and employee records.

Restricted data includes production credentials, encryption keys, customer payment details and identity documents. Restricted data may be stored only in the approved systems listed in the data register, and must never be sent by email or chat, even to colleagues. Confidential data may be shared outside the company only under a signed non-disclosure agreement.

SEC-07 Vendor and third-party security

Before a new vendor or SaaS tool can store Confidential or Restricted data, it must pass a vendor security review. The review takes up to 10 working days and checks the vendor's security certifications, where data will be stored and the vendor's history of breaches. Approved vendors are re-reviewed every 12 months, and immediately after any breach they disclose.

SEC-08 Access control

Access follows the principle of least privilege and is requested through the AccessHub portal. Managers review the access held by their team every quarter and remove anything that is no longer needed.

Production access is granted just in time through the Jumpgate bastion, for a maximum of 8 hours per approval. Every Jumpgate session is recorded. Accounts that have not been used for 60 days are disabled automatically.

When an employee leaves the company, all access is revoked within 4 hours of the end of their last working day. Managers must raise the offboarding request in AccessHub at least 3 working days before the last day.

SEC-09 Logging and monitoring

Security logs from laptops, NorthID and production systems are sent to the central security monitoring platform and are retained for 13 months. Application logs must never contain passwords, API keys or full payment card numbers. Alerts from the monitoring platform are triaged by the on-call security engineer.

SEC-10 Security incident response

Security incidents are classified by severity. SEV-1 means a confirmed exposure of Confidential or Restricted data, or an attacker with access to production. SEV-2 means a confirmed compromise of a single account or device with no evidence of data exposure. SEV-3 means suspicious activity or a policy violation with no confirmed compromise.

For a SEV-1 incident, the on-call security engineer starts containment within 30 minutes and an incident commander is appointed. The incident commander sends an update to the leadership team every 2 hours until the incident is contained. Affected customers are notified within 72 hours of the incident being confirmed.

How quickly employees must report a suspected incident is set out in the Employee Handbook. When in doubt, report it.

SEC-11 Security awareness

All employees complete security awareness training within 14 days of joining, and then once every year. The security team runs phishing simulations every quarter. Employees who click a simulated phishing link complete a 20-minute refresher module. Suspicious emails should be reported with the Report Phish button in the mail client.

SEC-12 Remote work and travel

When working from a public or shared network, employees must connect through NorthTunnel, the company VPN. Employees travelling to a country on the security team's high-risk list receive a loaner laptop for the trip and must not take their regular laptop.

SEC-13 Secure development

Secrets such as passwords, tokens and keys must be stored in the company secrets manager and never committed to source code. Every repository has secret scanning enabled, and a detected secret must be rotated within 24 hours, even if the commit was never pushed to a shared branch.

Third-party dependencies with critical vulnerabilities must be patched within 7 days, and those with high-severity vulnerabilities within 30 days. Exceptions follow the process in SEC-01.